

TALLER INTENSIVO: DFIR & OSINT

Sesión 5: Respuesta a Incidentes (IR)

Análisis de tráfico malicioso, IoCs y despliegue del Laboratorio Carnage.

// Instructor: QBit | Entorno:
Centrux

I. EL CICLO DE VIDA DE IR

Estructurando el caos tras la intrusión.

FASES NIST 800-61



1. Preparación

Establecer políticas, configurar herramientas (EDR, Firewalls) y entrenar al equipo. El incidente se gana o se pierde antes de que suceda.



2. Detección y Análisis

Identificar anomalías mediante alertas del SOC, correlacionar eventos (SIEM) y determinar el alcance real de la brecha de seguridad.



3. Contención y Erradicación

Aislar los sistemas infectados, eliminar el malware y cerrar los vectores de entrada para detener la exfiltración de datos.

EL ENEMIGO INVISIBLE

21

DÍAS (PROMEDIO)

Dwell Time (Tiempo de Permanencia)

Es el tiempo que transcurre desde que el atacante penetra la red hasta que es detectado por el Blue Team. Durante estos 21 días (promedio global), el atacante se mueve lateralmente, roba credenciales y prepara el despliegue del Ransomware.

Objetivo IR: Reducir el Dwell Time a horas.

FLUJO DE RESPUESTA



1. Alerta SOC

El sensor detecta tráfico anómalo saliente.



2. Triage Inicial

Se evalúa la criticidad y se asigna a un analista.



3. Deep Dive DFIR

Análisis forense de PCAP, RAM y disco local.



4. Remediación

Bloqueo de IPs de Comando y Control (C2).

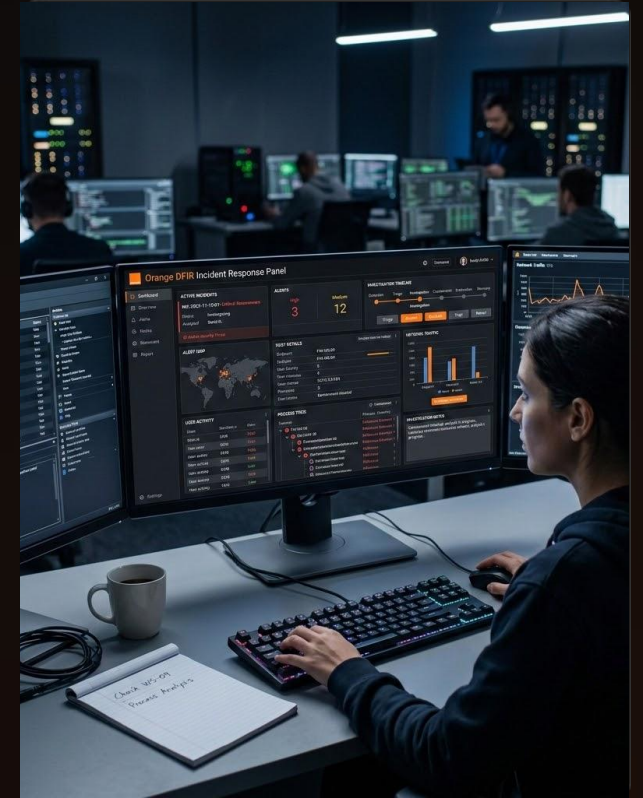
EL OBJETIVO DE DFIR

En medio de un incidente masivo, el equipo de Respuesta a Incidentes (IR) no busca hacer un peritaje judicial exhaustivo de meses. Busca **inteligencia procesable (Accionable Intel)**.

Necesitamos saber rápidamente:

- > ¿Cómo entraron? (Vector)
- > ¿Con qué servidores externos se comunican? (C2)
- > ¿Qué máquinas están infectadas? (Alcance)

Con esa información, podemos aplicar reglas de bloqueo y contener la hemorragia.



II. NETWORK FORENSICS

Destripando capturas de tráfico (PCAP).

PCAP VS LOGS DE HOST

Logs del Host (EDR/Sysmon)

Nos indican qué procesos se ejecutaron, qué archivos se modificaron en el disco y qué claves del registro cambiaron. Son vulnerables a manipulación: un atacante con privilegios de Root/SYSTEM puede borrar sus propios rastros del disco.

Tráfico de Red (PCAP)

Capturado a nivel de switch (Port Mirroring) o Firewall. Es evidencia externa a la máquina de la víctima. **El atacante no puede borrar los paquetes que ya salieron de la red corporativa.** Es la fuente de verdad absoluta.

LA VERDAD EN LA RED

||

"Los atacantes pueden ocultar malware en la memoria, pueden borrar los logs del disco, pero para robar datos o recibir comandos, eventualmente tienen que hablar por la red. Y la red nunca miente."

||

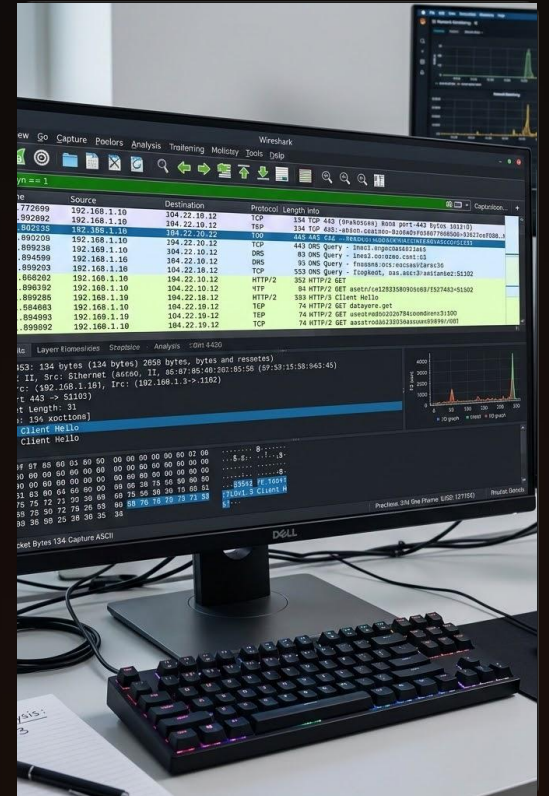
— AXIOMA DE NETWORK FORENSICS

HERRAMIENTAS: WIRESHARK

Wireshark es el analizador de protocolos de red por excelencia. Nos permite diseccionar archivos `.pcap` paquete por paquete.

No basta con abrir el archivo; un PCAP puede tener millones de paquetes. El arte del analista radica en utilizar **filtros de visualización** para eliminar el "ruido" legítimo (tráfico ARP, ruteo normal) y enfocarse en las anomalías.

La opción *"Follow TCP Stream"* nos permite ver la conversación completa reconstruida entre el atacante y la víctima.



FILTROS CLAVE DE WIRESHARK

Filtro de Display	Propósito Forense
http.request.method == "POST"	Busca envíos de datos (posible exfiltración o check-in de malware).
dns	Muestra resoluciones de dominios. Útil para cazar dominios maliciosos (DGA).
ip.addr == 192.168.1.10	Filtra todo el tráfico (entrante y saliente) de una IP víctima específica.
tcp.port == 4444	Filtra puertos anómalos. (4444 es el puerto por defecto de Metasploit).
http contains "exe"	Busca la descarga directa de archivos ejecutables no cifrados.

III. INTELIGENCIA DE AMENAZAS

Cyber Threat Intelligence (CTI) & IoCs

¿QUÉ ES UN IOC?

-  **Indicador de Compromiso (IoC):** Es cualquier fragmento de evidencia técnica que sugiere fuertemente que una red ha sido vulnerada.
-  El equipo DFIR extrae los IoCs del análisis de la evidencia (PCAP, Memoria) y los comparte con el equipo de Defensa (Blue Team) para bloquear la amenaza.
-  Los compartimos en formatos estandarizados (STIX/TAXII) con la comunidad para alertar sobre nuevas campañas de malware.

LA PIRÁMIDE DEL DOLOR

||

"No todos los indicadores tienen el mismo valor. Bloquear el Hash de un virus es fácil, pero el atacante lo cambia en 1 segundo. Descubrir y bloquear su táctica (TTPs) le causa un dolor real."

||

— DAVID BIANCO (CREADOR DE LA PYRAMID OF PAIN)

NIVELES DE LA PIRÁMIDE

Indicador (IoC)	Dolor para el Atacante	Ejemplo
Hash Values (MD5, SHA)	Trivial	d41d8cd98f00b204e980...
IP Addresses	Fácil	185.12.5.44
Domain Names	Simple	malicious-update.com
Network / Host Artifacts	Molesto	Un User-Agent raro, llave de Registro.
Tools (Herramientas)	Desafiante	Detectar la firma de Mimikatz/Cobalt.

OSINT Y ENRIQUECIMIENTO

VirusTotal

No suban archivos confidenciales de clientes a VirusTotal. Utilicen VT exclusivamente para consultar Hashes (MD5/SHA256) o IPs que hayan extraído del PCAP para ver si otros vendors ya los marcaron como maliciosos (Cobalt Strike, Emotet, etc.).

AbuseIPDB & AlienVault

Plataformas de OSINT para enriquecer IPs sospechosas. Si ven una conexión a una IP rusa y AbuseIPDB reporta 15,000 quejas de escaneo de puertos en esa IP, tienen confirmación externa de actividad anómala.

IV. LABORATORIO "CARNAGE"

EL CONTEXTO DEL INCIDENTE

El inicio: Eric, del departamento de Compras, recibió un correo electrónico engañoso.

Descargó un documento de Word adjunto.

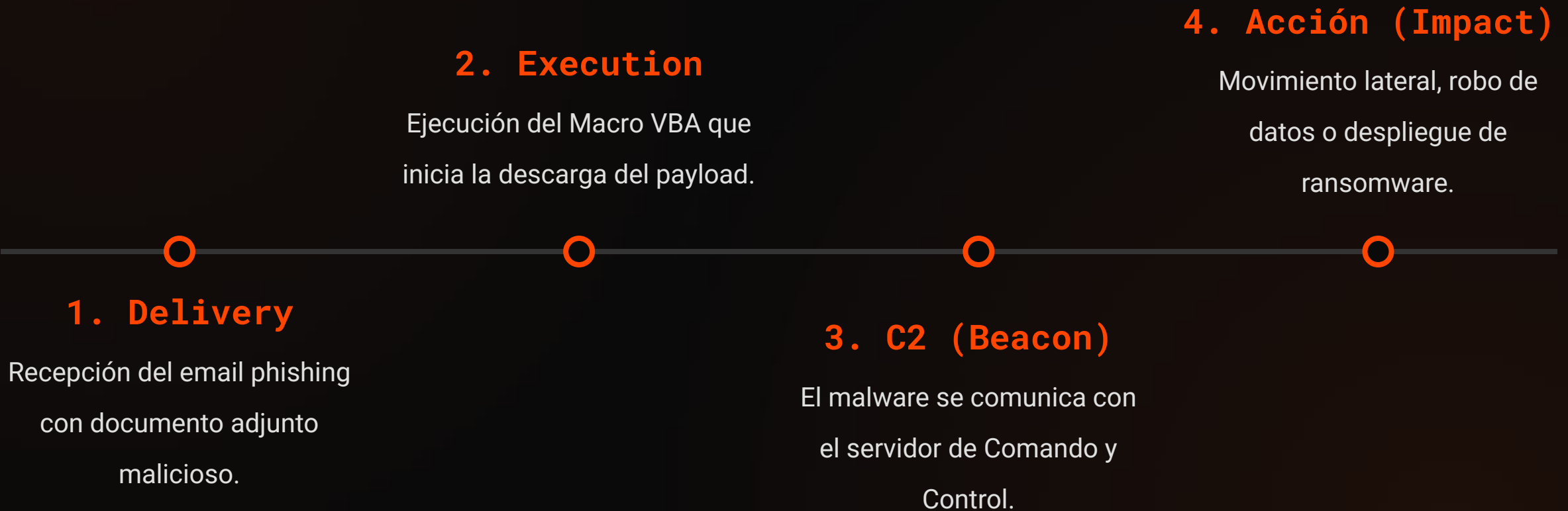
El error fatal: Al abrir el documento, Eric hizo clic en "*Habilitar Contenido*" (Enable Content).

Esto ejecutó un macro (VBA) incrustado de forma invisible.

La Alerta: El departamento SOC recibió inmediatamente una alerta del sensor de red: la estación de trabajo de Eric estaba realizando conexiones salientes sospechosas.



CADENA DE INFECCIÓN



ARSENAL DEL ATACANTE



Macros (VBA)

Un método clásico de Initial Access. El código se ofusca dentro del documento de Office y actúa como un "Dropper" (descargador) del malware principal.



Cobalt Strike

Una herramienta comercial de Red Teaming altamente abusada por cibercriminales y grupos APT. Genera "Beacons" indetectables que se comunican por HTTPS.

COMANDO Y CONTROL (C2)

¿Qué es el C2?

Es el servidor controlado por el atacante en internet. Una vez que el malware infecta la máquina de Eric, hace una llamada de vuelta (Call Home) a esta IP para pedir instrucciones ("¿Qué encripto?", "¿Qué archivos robo?").

Nuestra Misión

Como analistas DFIR, debemos encontrar en el archivo PCAP exactamente a qué direcciones IP, dominios y en qué fecha/hora la máquina de Eric comenzó a realizar estas conexiones clandestinas (Beacons).

ANÁLISIS DE LA EVIDENCIA

PCAP

PACKET CAPTURE

La Evidencia Cruda

Se nos entregó un archivo `.pcap` extraído del sensor perimetral de la empresa. Este archivo contiene TODO el tráfico de red de la víctima durante el incidente.

La tarea es aislar la señal (el ataque) del ruido (el tráfico normal).

OBJETIVOS DEL ANALISTA

- ❌ Identificar la **fecha y hora exactas** de la primera conexión maliciosa (Punto Cero).
- ❌ Rastrear las consultas **DNS** y descubrir los 3 dominios involucrados en el ataque.
- ❌ Extraer las direcciones IP sospechosas y validarlas externamente (VirusTotal) para confirmar si pertenecen a infraestructura **Cobalt Strike**.
- ❌ Determinar el nombre y el hash (MD5) del archivo malicioso descargado.

ADVERTENCIA DE SEGURIDAD

REGLA DE ORO (OPSEC)

No interactuar NUNCA directamente con dominios o direcciones IP descubiertas en el laboratorio. El entorno C2 (Cobalt Strike) puede seguir activo en internet. Utilicen únicamente herramientas pasivas como VirusTotal para investigar la infraestructura maliciosa sin comprometer sus equipos.



PREGUNTAS

Abran Wireshark y el archivo PCAP. Arrancamos el
Laboratorio.

Taller Intensivo OSINT & DFIR